

Project P6: Web Attack Detection with Splunk

Apache Access Telemetry Ingestion, Search-Time URL Decoding, Multi-Vector Attack Classification & SOC Dashboarding

INCIDENT / DOC ID	INVESTIGATING ANALYST	INVESTIGATION DATE	CLASSIFICATION
INC-2026-P6-001	Natto Chakma	September 14, 2026	TLP:CLEAR
TARGET WEB HOST	ADVERSARY NODE	SIEM ARCHITECTURE	INGESTION INDEX / TELEMETRY
ubuntu-p3 (192.168.100.9)	192.168.100.6 (Kali Linux)	Splunk Enterprise 10.4.3	index=web (access_combined)

1. Executive Summary

During real-time threat monitoring within the Splunk SOC laboratory, security detection alerts were triggered indicating an aggressive, multi-vector web application reconnaissance and exploitation campaign targeting the Apache2 web server hosted on ubuntu-p3 (192.168.100.9). Telemetry ingested via the **Splunk Universal Forwarder** from /var/log/apache2/access.log surfaced a structured adversary engagement launched from the Kali Linux host (192.168.100.6):

Key Incident Findings: Telemetry captured and parsed multiple high-severity exploitation vectors: (1) **SQL Injection probes** attempting authentication bypass (admin'OR'1'='1) and schema extraction (UNION SELECT); (2) **Cross-Site Scripting (XSS) probes** injecting script tags and DOM event handlers (<script>, onerror=, onload=); (3) **Directory Traversal / LFI** attempts probing sensitive Unix/Windows configuration files (/etc/passwd, /etc/shadow, win.ini); (4) **Offensive Tool Scanners** identifying automated agents including Nikto/2.1.6, sqlmap/1.6.12#stable, gobuster/3.1.0, DirBuster-1.0-RC1, and Nmap Scripting Engine; and (5) **Directory fuzzing** generating high-frequency HTTP 404 status bursts. All activities were normalized with URL decoding and correlated on the operational SOC dashboard.

2. Lab Scope & Telemetry Architecture

System Node	Network IP	Operating System	Role in Telemetry Pipeline
Web Target	192.168.100.9	Ubuntu Linux (ubuntu-p3)	Apache/2.4.58 web server forwarding /var/log/apache2/access.log via Splunk Universal Forwarder.
Adversary Host	192.168.100.6	Kali Linux 2026 (Rolling)	Dedicated attacker executing curl-based exploits, automated vulnerability scanners, and directory fuzzing.
SIEM Server	192.168.100.7	Ubuntu Server 24.04 LTS	Splunk Enterprise 10.4.3 indexer and search head hosting index=web and operational SOC dashboards.
Monitored Endpoint	192.168.100.8	Windows 11 Enterprise	Endpoint baseline monitored in companion projects (P1–P5).

3. Web Attack Vectors & Exploitation Mechanics

- SQL Injection (T1190):** The adversary submitted union-based queries and boolean tautologies within HTTP GET parameters to evaluate database parsing and extract user credentials without authentication.
- Cross-Site Scripting (T1059.007):** Reflected script injections and event handlers were submitted against application parameters, attempting client-side script execution and session token access.
- Directory Traversal & LFI (T1083 / T1005):** Probes utilized directory climb sequences (../../../../ and percent-encoded variants ..%2f) targeting system accounts (/etc/passwd) and shadow password hashes (/etc/shadow).
- Automated Tool Fingerprinting (T1595):** Vulnerability assessment suites were executed directly against the web root, exposing well-known offensive user-agent strings that require perimeter automated dropping.
- Directory Fuzzing & 404 Status Surge:** High-velocity endpoint discovery probing common administrative paths (/admin, /login, /config, /test) generated measurable 404 error spikes.

4. Search-Time Telemetry Engineering & URL Decoding

Modern web application attacks frequently leverage percent-encoding (e.g., %27%200R%201=1 or .%2f..%2f) to obfuscate malicious strings. The Splunk detection pipeline applies search-time URL normalization using `coalesce(urldecode(uri), uri)` to ensure both encoded and cleartext payloads are detected:

```
index=web sourcetype=access_combined
| eval clean_uri=coalesce(urldecode(uri), uri)
| eval attack_type=case(
  match(clean_uri, "(?i)(union\\s+select|select\\s+.*\\s+from|'\\s*or\\s*'1='1|information_schema|order\\s+by\\s+\\d+|sleep\\(\\d+\\)|benchmark\\(|waitfor\\s+delay|drop\\s+table)"), "SQL Injection (T1190)",
  match(clean_uri, "(?i)(<script|\\%3Cscript|javascript:|onerror|onload|alert|document\\.cookie|eval\\(|<img|<svg)"), "Cross-Site Scripting (T1059.007)",
  match(clean_uri, "(?i)(\\.\\.\\.|\\.\\.\\.\\.|\\.\\.\\.\\%2f|\\.\\.\\.\\%5c|/etc/passwd|/etc/shadow|boot\\.ini|win\\.ini)"), "Directory Traversal / LFI (T1083)",
  match(useragent, "(?i)(nikto|sqlmap|gobuster|dirbuster|nmap|masscan|wpscan|hydra)"), "Vulnerability Scanner (T1595)",
  status >= 400, "Client Error (HTTP " . status . ")",
  true(), "Benign Request"
)
| search attack_type!="Benign Request"
| eval formatted_time=strftime(_time, "%Y-%m-%d %H:%M:%S")
| table formatted_time clientip method uri status useragent attack_type
```

Adversary Emulation Commands & Server Responses

```
# Adversary Multi-Vector Attack Suite (Kali Linux 192.168.100.6)
curl -s "http://192.168.100.9/?id=1'+OR+'1='1"
curl -s "http://192.168.100.9/search?q=%3Cscript%3Ealert('XSS')%3C/script%3E"
curl -s "http://192.168.100.9/download.php?file=../../../../etc/passwd"
curl -s -A "Nikto/2.1.6" "http://192.168.100.9/test/"
for dir in admin login config backup db; do curl -s -o /dev/null "http://192.168.100.9/$dir"; done
```

Apache 2.4 server response payload captured during exploit delivery:

```
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head><title>404 Not Found</title></head>
<body><h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr><address>Apache/2.4.58 (Ubuntu) Server at 192.168.100.9 Port 80</address>
</body></html>
```

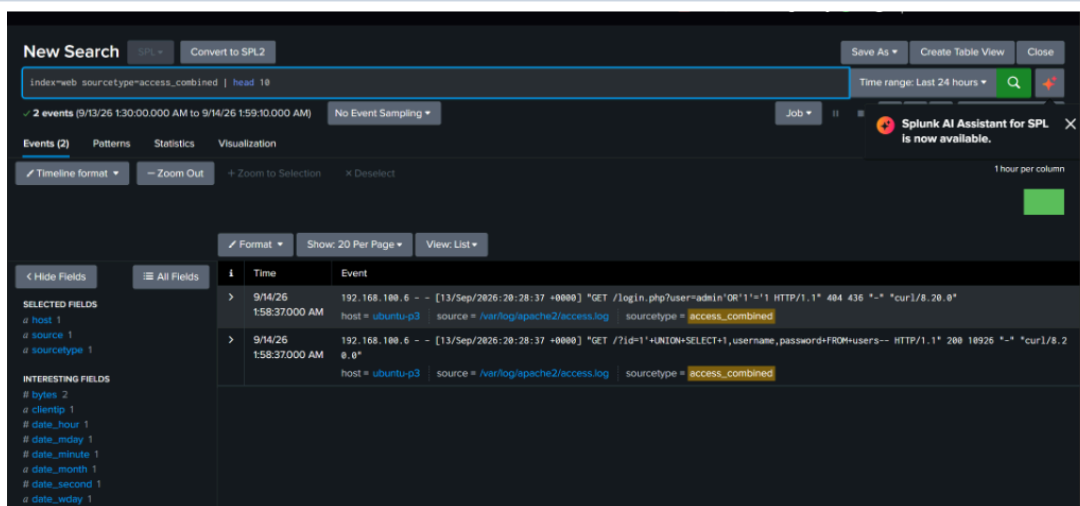


Figure 4.1: Splunk Search Head confirming Apache access_combined log ingestion from ubuntu-p3 into index=web with active attack parameters.

5. Operational SOC Web Security Threat Dashboard

An interactive, dark-mode Simple XML SOC dashboard was deployed to provide Tier-1 and Tier-2 analysts with real-time visibility into incoming web threats, category distributions, client sources, and live high-severity triage tables.

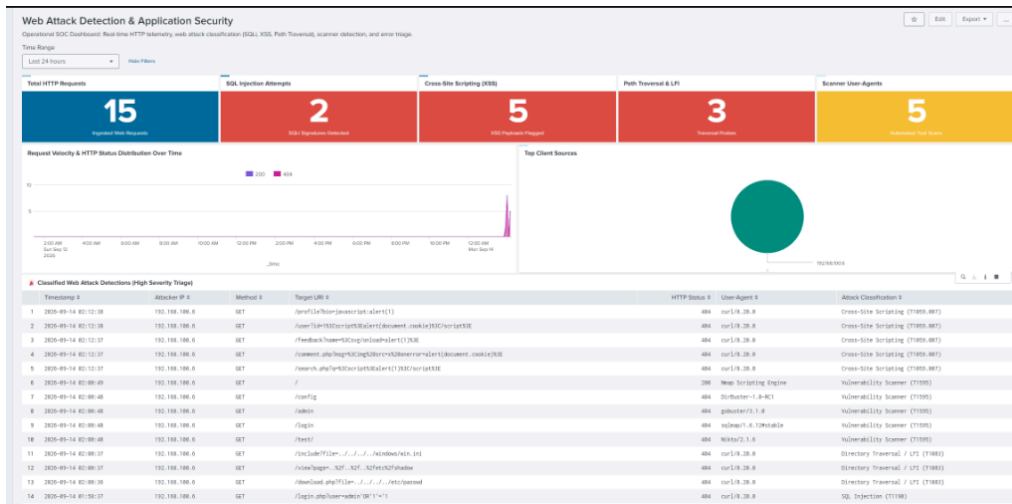


Figure 5.1: Operational SOC dashboard displaying 15 total HTTP requests, 2 SQLi detections (Red Alert), 5 XSS payloads flagged (Red Alert), 3 Path Traversal probes (Red Alert), 5 Scanner tool alerts (Yellow Alert), request velocity timeline, and classified triage table.

6. Forensic Web Attack Triage Stream

Timestamp (UTC)	Attacker IP	Method	Target URI / Query	HTTP	User-Agent	Classification
02:13:20	192.168.100.6	GET	/user?id=1%3Cscript%3Ealert...	404	curl/8.20.0	Cross-Site Scripting (T1059.007)
02:13:20	192.168.100.6	GET	/comment.php?msg=%3Cimg%20src=x...	404	curl/8.20.0	Cross-Site Scripting (T1059.007)
02:13:19	192.168.100.6	GET	/search.php?q=%3Cscript%3Ealert(1)...	404	curl/8.20.0	Cross-Site Scripting (T1059.007)
02:00:49	192.168.100.6	GET	/	200	Nmap Scripting Engine	Vulnerability Scanner (T1595)
02:00:48	192.168.100.6	GET	/config	404	DirBuster-1.0-RC1	Vulnerability Scanner (T1595)
02:00:48	192.168.100.6	GET	/admin	404	gobuster/3.1.0	Vulnerability Scanner (T1595)
02:00:48	192.168.100.6	GET	/login	404	sqlmap/1.6.12#stable	Vulnerability Scanner (T1595)
02:00:48	192.168.100.6	GET	/test/	404	Nikto/2.1.6	Vulnerability Scanner (T1595)
02:00:37	192.168.100.6	GET	/include?file=../../../../windows/win.ini	404	curl/8.20.0	Path Traversal / LFI (T1083)
02:00:37	192.168.100.6	GET	/view?page=..%2f..%2f..%2fetc%2fshadow	404	curl/8.20.0	Path Traversal / LFI (T1083)
02:00:36	192.168.100.6	GET	/download.php?file=../../../../etc/passwd	404	curl/8.20.0	Path Traversal / LFI (T1083)
01:58:37	192.168.100.6	GET	/login.php?user=admin'OR'1'='1	404	curl/8.20.0	SQL Injection (T1190)
01:58:37	192.168.100.6	GET	?id=1'+UNION+SELECT+1,username...	200	curl/8.20.0	SQL Injection (T1190)

7. MITRE ATT&CK Framework Alignment

Tactic	Technique Name	ATT&CK ID	Lab Evidence & Detection Application
Initial Access	Exploit Public-Facing Application	T1190	SQL Injection queries submitted to bypass authentication and query underlying tables.
Execution	Command & Scripting: JavaScript	T1059.007	Cross-Site Scripting probes injecting inline script tags and event handler attributes.
Reconnaissance	Active Scanning: Vulnerability Scanning	T1595.002	Offensive tool probing using Nikto, sqlmap, gobuster, DirBuster, and Nmap.
Discovery	File and Directory Discovery	T1083	Directory traversal payloads attempting to identify and locate system-level configuration files.
Collection	Data from Local System	T1005	Path traversal probes targeting sensitive credentials in /etc/shadow and win.ini.

8. Analyst Recommendations & Defense-in-Depth Remediation

1. Deploy Web Application Firewall (ModSecurity with OWASP CRS):

Install and enforce ModSecurity on Apache2 to inspect incoming URI parameters and request bodies, blocking SQLi, XSS, and traversal before reaching web applications:

```
sudo apt install -y libapache2-mod-security2
sudo cp /etc/modsecurity/modsecurity.conf-recommended /etc/modsecurity/modsecurity.conf
sudo sed -i 's/SecRuleEngine DetectionOnly/SecRuleEngine On/' /etc/modsecurity/modsecurity.conf
sudo systemctl restart apache2
```

- Mandate Parameterized Prepared Statements:** Disallow direct SQL string concatenation in backend application code. Enforce parameterized queries across all database drivers.
- Input Whitelisting & Output Encoding:** Enforce strict contextual output encoding (HTML, JavaScript, CSS) to neutralize XSS attacks, and implement Content Security Policy (CSP) headers.
- Perimeter Dropping of Offensive Scanner User-Agents:** Configure Apache reverse-proxy rules or Cloudflare edge rules to automatically drop requests originating from known automated vulnerability scanners (Nikto, sqlmap, gobuster, DirBuster).
- Automate Splunk Alerting:** Schedule sqli-detection.sp1 and xss-detection.sp1 to run every 5 minutes in Splunk Enterprise, automatically alerting the SOC on Slack/PagerDuty upon pattern match.

